



# Introduction

You're thinking about becoming a Certified Ethical Hacker (CEH). No matter what variation of security testing you are performing—ethical hacking, penetration testing, red teaming, or application assessment—the skills and knowledge necessary to achieve this certification are in demand. Even the idea of security testing and ethical hacking is evolving as businesses and organizations begin to have a better understanding of the adversaries they are facing. It's no longer the so-called script kiddies that businesses felt they were fending off for so long. Today's adversary is organized, well-funded, and determined. This means testing requires different tactics.

Depending on who you are listening to, 80–90 percent of attacks today use social engineering. The old technique of looking for technical vulnerabilities in network services is simply not how attackers are getting into networks. Networks that are focused on applying a defense-in-depth approach, hardening the outside, may end up being susceptible to attacks from the inside, which is what happens when desktop systems are compromised. The skills needed to identify vulnerabilities and recommend remediations are evolving, along with the tactics and techniques used by attackers.

This book is written to help you understand the breadth of content you will need to know to obtain the CEH certification. You will find a lot of concepts to provide you with a foundation that can be applied to the skills required for the certification. While you can read this book cover to cover, for a substantial chunk of the subjects, getting hands-on experience is essential. The concepts are often demonstrated through the use of tools. Following along with these demonstrations

and using the tools yourself will help you understand the tools and how to use them. Many of the demonstrations are done in Kali Linux, though many of the tools have Windows analogs if you are more comfortable there.

We can't get through this without talking about ethics, though you will find it mentioned in several places throughout the book. This is serious, and not only because it's a huge part of the basis for the certification. It's also essential for protecting yourself and the people you are working for. The short version is do not do anything that would cause damage to systems or your employer. There is much more to it than that, which you'll read more about in [Chapter 1](#), “Ethical Hacking,” as a starting point. It's necessary to start wrapping your head around the ethics involved in this exam and profession. You will have to sign an agreement as part of achieving your certification.

At the end of each chapter, you will find a set of questions. This will help you to demonstrate to yourself that you understand the content. Most of the questions are multiple choice, which is the question format used for the CEH exam. These questions, along with the hands-on experience you take advantage of, will be good preparation for taking the exam.

## What Is a CEH?

The Certified Ethical Hacker exam is to validate that those holding the certification understand the broad range of subject matter that is required for someone to be an effective ethical hacker. The reality is that most days, if you are paying attention to the news, you will see a news story about a company that has been compromised and had data stolen, a government that has been attacked, or even enormous denial-of-service attacks, making it difficult for users to gain access to business resources.

The CEH is a certification that recognizes the importance of identifying security issues to get them remediated. This is one way companies can protect themselves against attacks—by getting there before the attackers do. It requires someone who knows how to follow techniques that attackers would normally use. Just running scans using automated tools is insufficient because as good as security scanners may be, they will identify false positives—cases where the scanner indicates an issue that isn't really an issue. Additionally, they will miss a lot of vulnerabilities—false negatives—for a variety of reasons, including the fact that the vulnerability or attack may not be known.

Because companies need to understand where they are vulnerable to attack, they need people who are able to identify those vulnerabilities, which can be very complex. Scanners are a good start, but being able to find holes in complex networks can take the creative intelligence that humans offer. This is why we need ethical hackers. These are people who can take extensive knowledge of a broad range of technical subjects and use it to identify vulnerabilities that can be exploited.

The important part of that two-word phrase, by the way, is “ethical.” Companies have protections in place because they have resources they don't want stolen or damaged. When they bring in someone who is looking for vulnerabilities to exploit, they need to be certain that nothing will be stolen or damaged. They also need to be certain that anything that may be seen or reviewed isn't shared with anyone else. This is especially true when it comes to any vulnerabilities that have been identified.

The CEH exam, then, has a dual purpose. It not only tests deeply technical knowledge but also binds anyone who is a certification holder to a code of conduct. Not only will you be expected to know the content and expectations of that code of conduct, you will be expected to live by that code. When companies hire or contract to people who have their CEH certification, they can be assured they have brought on someone with discretion who can keep their secrets and provide them

with professional service in order to help improve their security posture and keep their important resources protected.

## The Subject Matter

If you were to take the CEH v12 training, you would have to go through the following modules:

- Introduction to Ethical Hacking
- Footprinting and Reconnaissance
- Scanning Networks
- Enumeration
- Vulnerability Analysis
- System Hacking
- Malware Threats
- Sniffing
- Social Engineering
- Denial of Service
- Session Hijacking
- Evading IDSs, Firewalls, and Honeypots
- Hacking Web Servers
- Hacking Web Applications
- SQL Injection
- Hacking Wireless Networks
- Hacking Mobile Platforms
- IoT and OT Hacking
- Cloud Computing
- Cryptography

As you can see, the range of subjects is broad. Beyond knowing the concepts associated with these topics, you will be expected to know about various tools that may be used to perform the actions associated with the concepts you are learning. You will need to know tools like `nmap` for port scanning, for example. You may need to know proxy-based web application attack tools. For wireless network attacks, you

may need to know about the `aircrack-ng` suite of tools. For every module listed, there are potentially dozens of tools that may be used.

The subject matter of the CEH exam is very technical. This is not a field in which you can get by with theoretical knowledge. You will need to have had experience with the methods and tools that are covered within the subject matter for the CEH exam. What you may also have noticed here is that the modules all fall within the different stages mentioned earlier. While you may not necessarily be asked for a specific methodology, you will find that the contents of the exam do generally follow the methodology that the EC-Council believes to be a standard approach.

## About the Exam

The CEH exam has much the same parameters as other professional certification exams. You will take a computerized, proctored exam. You will have 4 hours to complete 125 questions. That means you will have, on average, roughly 2 minutes per question. The questions are all multiple choice. The exam can be taken through the ECC Exam Center or at a Pearson VUE center. For details about VUE, please visit <https://home.pearsonvue.com/eccouncil>.

Should you want to take your certification even further, you could go after the CEH Practical exam. For this exam you must perform an actual penetration test and write a report at the end of it. This demonstrates that in addition to knowing the body of material covered by the exam, you can put that knowledge to use in a practical way. You will be expected to know how to compromise systems and identify vulnerabilities.

To pass the exam, you will have to correctly answer a certain number of questions, though the actual number will vary. The passing grade varies depending on the difficulty of the questions asked. The harder the questions that are asked out of the complete pool of questions, the

fewer questions you need to get right to pass the exam. If you get easier questions, you will need to get more of the questions right to pass. There are some sources of information that will tell you that you need to get 70 percent of the questions right, and that may be okay for general guidance and preparation as a rough low-end marker. However, keep in mind that when you sit down to take the actual test at the testing center, the passing grade will vary. The score you will need to achieve will range from 60 to 85 percent.

The good news is that you will know whether you passed before you leave the testing center. You will get your score when you finish the exam, and you will also get a piece of paper indicating the details of your grade. You will get feedback associated with the different scoring areas and how you performed in each of them.

## Who Is Eligible

Not everyone is eligible to sit for the CEH exam. Before you go too far down the road, you should check your qualifications. Just as a starting point, you have to be at least 18 years of age. The other eligibility standards are as follows:

- Anyone who has versions 1–7 of the CEH certification. The CEH certification is ANSI certified now, but early versions of the exam were available before the certification. Anyone who wants to take the ANSI-accredited certification who has the early version of the CEH certification can take the exam.
- Minimum of two years of related work experience. Anyone who has the experience will have to pay a nonrefundable application fee of \$100.
- Have taken an EC-Council training.

If you meet these qualification standards, you can apply for the certification, along with paying the fee if it is applicable to you (if you take

one of the EC-Council trainings, the fee is included). The application will be valid for three months.

## Exam Cost

To take the certification exam, you need to pay for a Pearson VUE exam voucher. The cost of this is \$1,199. You could also obtain an EC-Council voucher for \$950, but that requires that you have taken EC-Council training and can provide a Certificate of Attendance.



EC-Council may change their eligibility, pricing, or exam policies from time to time. We highly encourage you to check for updated policies at the EC-Council website (<https://cert.eccouncil.org/certified-ethical-hacker.html>) when you begin studying for this book and again when you register for this exam.

---

## About EC-Council

The International Council of Electronic Commerce Consultants is more commonly known as the EC-Council ([www.eccouncil.org](http://www.eccouncil.org)). It was created after the airplane attacks that happened against the United States on September 11, 2001. The founder, Jay Bavisi, wondered what would happen if the perpetrators of the attack decided to move from the kinetic world to the digital world. Even beyond that particular set of attackers, the Internet has become a host to a large number of people who are interested in causing damage or stealing information. The economics of the Internet, meaning the low cost of entry into the business, encourage criminals to use it as a means of stealing information, ransoming data, or other malicious acts.

The EC-Council is considered to be one of the largest certifying bodies in the world. It operates in 145 countries and has certified more than 200,000 people. In addition to the CEH, the EC-Council administers a number of other IT-related certifications:

- Certified Network Defender (CND)
- Certified Ethical Hacker Practical
- EC-Council Certified Security Analyst (ECSA)
- EC-Council Certified Security Analyst Practical
- Licensed Penetration Tester (LPT)
- Computer Hacking Forensic Investigator (CHFI)
- Certified Chief Information Security Officer (CCISO)

One advantage to holding a certification from the EC-Council is that the organization has been accredited by the American National Standards Institute (ANSI). Additionally, and perhaps more importantly for potential certification holders, the certifications from EC-Council are recognized worldwide and have been endorsed by governmental agencies like the National Security Agency (NSA). The Department of Defense Directive 8570 includes the CEH certification. This is important because having the CEH certification means that you could be quickly qualified for a number of positions with the United States government.

The CEH certification provides a bar. This means there is a set of known standards. To obtain the certification, you will need to have met at least the minimal standards. These standards can be relied on consistently. This is why someone with the CEH certification can be trusted. They have demonstrated that they have met known and accepted standards of both knowledge and professional conduct.

## Using This Book

This book is structured in a way that foundational material is up front. With this approach, you can make your way in an orderly fashion



through the book, one chapter at a time. Technical books can be dry and difficult to get through sometimes, but it's always my goal to try to make them easy to read and I hope entertaining along the way. If you already have a lot of experience, you don't need to take the direct route from beginning to end. You can skip around as you need. No chapter relies on any other. They all stand alone with respect to the content. However, if you don't have the foundation and try to jump to a later chapter, you may find yourself getting lost or confused by the material. All you need to do is jump back to some of the foundational chapters.

Beyond the foundational materials, the book generally follows a fairly standard methodology when it comes to performing security testing. This methodology will be further explained in [Chapter 1](#). As a result, you can follow along with the steps of a penetration test/ethical hacking engagement. Understanding the outline and reason for the methodology will also be helpful to you. Again, though, if you know the material, you can move around as you need.

## Additional Study Tools

This book is accompanied by an online learning environment that provides several additional elements. The following items are available among these companion files:

- **Practice tests** All of the questions in this book appear in our proprietary digital test engine—including the 30-question assessment test at the end of this introduction and the 100+ questions that make up the review question sections at the end of each chapter. In addition, there are four bonus exams, each 125 questions.
- **Electronic “flashcards”** The digital companion files include more than 100 questions in flashcard format (a question followed by a single correct answer). You can use these to review your knowledge of the exam objectives.

- **Glossary** The key terms from this book, and their definitions, are available as a fully searchable PDF.

---

#### INTERACTIVE ONLINE LEARNING ENVIRONMENT AND TEST BANK

To start using additional online materials that accompany this book to study for the Certified Ethical Hacker exam, go to [www.wiley.com/go/sybextestprep](http://www.wiley.com/go/sybextestprep) and click the link “Click here to register a product” to receive your unique PIN. Once you have the PIN, return to [www.wiley.com/go/sybextestprep](http://www.wiley.com/go/sybextestprep), find your book and click Register or Login, and follow the link to create a new account or add this book to an existing account.

---



Like all exams, the CEH certification from EC-Council is updated periodically and may eventually be retired or replaced. At some point after EC-Council is no longer offering this exam, the old editions of our books and online tools will be retired. If you have purchased this book after the exam was retired, or are attempting to register in the Sybex online learning environment after the exam was retired, please know that we make no guarantees that this exam's online Sybex tools will be available once the exam is no longer available.

---

## Objective Map

**Table 1.1** contains an objective map to show you at a glance where in the book you can find each objective covered. While there are chapters listed for all of these, there are some objectives that are scattered throughout the book. Specifically, tools, systems, and programs get at least touched on in most of the chapters.

**TABLE 1.1** Objective Map

| Objective                                | Chapter                                                          |
|------------------------------------------|------------------------------------------------------------------|
| <b>Tasks</b>                             |                                                                  |
| 1.1 Systems development and management   | <u>7</u> , <u>14</u>                                             |
| 1.2 Systems analysis and audits          | <u>4</u> , <u>5</u> , <u>6</u> , <u>7</u>                        |
| 1.3 Security testing and vulnerabilities | <u>7</u> , <u>8</u>                                              |
| 1.4 Reporting                            | <u>1</u> , <u>7</u>                                              |
| 1.5 Mitigation                           | <u>7</u> , <u>8</u>                                              |
| 1.6 Ethics                               | <u>1</u>                                                         |
| <b>Knowledge</b>                         |                                                                  |
| 2.1 Background                           | <u>2</u> , <u>3</u>                                              |
| 2.2 Analysis/assessment                  | <u>2</u> , <u>11</u>                                             |
| 2.3 Security                             | <u>3</u> , <u>13</u> , <u>14</u>                                 |
| 2.4 Tools, systems, programs             | <u>4</u> , <u>5</u> , <u>6</u> , <u>7</u>                        |
| 2.5 Procedures/methodology               | <u>1</u> , <u>4</u> , <u>5</u> , <u>6</u> , <u>7</u> , <u>14</u> |
| 2.6 Regulation/policy                    | <u>1</u> , <u>14</u>                                             |
| 2.7 Ethics                               | <u>1</u>                                                         |

## Let's Get Started!

This book is structured in a way that you will be led through foundational concepts and then through a general methodology for ethical hacking. You can feel free to select your own pathway through the book. Remember, wherever possible, get your hands dirty. Get some experience with tools, tactics, and procedures that you are less familiar with. It will help you a lot.

Take the self-assessment. It may help you get a better idea of how you can make the best use of this book.

## How to Contact the Publisher

If you believe you've found a mistake in this book, please bring it to our attention. At John Wiley & Sons, we understand how important it is to provide our customers with accurate content, but even with our best efforts an error may occur.

In order to submit your possible errata, please email it to our Customer Service Team at [wileysupport@wiley.com](mailto:wileysupport@wiley.com) with the subject line "Possible Book Errata Submission."

## Assessment Test

1. Which header field is used to reassemble fragmented IP packets?
  - A. Destination address
  - B. IP identification
  - C. Don't fragment bit
  - D. ToS field
2. If you were to see the following in a packet capture, what would you expect was happening?

```
' or 1=1;
```

- A. Cross-site scripting
  - B. Command injection
  - C. SQL injection
  - D. XML external entity injection
3. What method might you use to successfully get malware onto a mobile device?
- A. Through the Apple Store or Google Play Store
  - B. External storage on an Android
  - C. Third-party app store
  - D. Jailbreaking
4. What protocol is used to take a destination IP address and get a packet to a destination on the local network?
- A. DHCP
  - B. ARP
  - C. DNS
  - D. RARP
5. What would be the result of sending the string  
AAAAAAAAAAAAAAAAAAAA into a variable that has been allocated space for 8 bytes?
- A. Heap spraying
  - B. SQL injection
  - C. Buffer overflow
  - D. Slowloris attack
6. If you were to see the subnet mask 255.255.248.0, what CIDR notation (prefix) would you use to indicate the same thing?
- A. /23
  - B. /22
  - C. /21
  - D. /20
7. What is the primary difference between a worm and a virus?
- A. A worm uses polymorphic code.
  - B. A virus uses polymorphic code.
  - C. A worm can self-propagate.
  - D. A virus can self-propagate.
8. How would you calculate risk?

- A. Probability \* loss
  - B. Probability \* mitigation factor
  - C. (Loss + mitigation factor) \* (loss/probability)
  - D. Loss \* mitigation factor
9. How does an evil twin attack work?
- A. Phishing users for credentials
  - B. Spoofing an SSID
  - C. Changing an SSID
  - D. Injecting four-way handshakes
10. To remove malware in the network before it gets to the endpoint, you would use which of the following?
- A. Antivirus
  - B. Application layer gateway
  - C. Unified threat management appliance
  - D. Stateful firewall
11. What is the purpose of a security policy?
- A. Providing high-level guidance on the role of security
  - B. Providing specific direction to security workers
  - C. Increasing the bottom line of a company
  - D. Aligning standards and practices
12. What has been done to the following string?

```
%3Cscript%3Ealert('wubble');%3C/script%3E
```

- A. Base64 encoding
  - B. URL encoding
  - C. Encryption
  - D. Cryptographic hashing
13. What would you get from running the command `dig ns domain.com`?
- A. Mail exchanger records for `domain.com`
  - B. Name server records for `domain.com`
  - C. Caching name server for `domain.com`
  - D. IP address for the hostname `ns`

14. What technique would you ideally use to get all of the hostnames associated with a domain?
- A. DNS query
  - B. Zone copy
  - C. Zone transfer
  - D. Recursive request
15. If you were to notice operating system commands inside a DNS request while looking at a packet capture, what might you be looking at?
- A. Tunneling attack
  - B. DNS amplification
  - C. DNS recursion
  - D. XML entity injection
16. What would be the purpose of running a ping sweep?
- A. You want to identify responsive hosts without a port scan.
  - B. You want to use something that is light on network traffic.
  - C. You want to use a protocol that may be allowed through the firewall.
  - D. All of the above.
17. How many functions are specified by NIST's cybersecurity framework?
- A. 0
  - B. 3
  - C. 5
  - D. 4
18. What would be one reason not to write malware in Python?
- A. The Python interpreter is slow.
  - B. The Python interpreter may not be available.
  - C. There is inadequate library support.
  - D. Python is a hard language to learn.
19. If you saw the following command line, what would you be capturing?

```
tcpdump -i eth2 host 192.168.10.5
```

- A. Traffic just from 192.168.10.5
  - B. Traffic to and from 192.168.10.5
  - C. Traffic just to 192.168.10.5
  - D. All traffic other than from 192.168.10.5
20. What is Diffie-Hellman used for?
- A. Key management
  - B. Key isolation
  - C. Key exchange
  - D. Key revocation
21. Which social engineering principle may allow a phony call from the help desk to be effective?
- A. Social proof
  - B. Imitation
  - C. Scarcity
  - D. Authority
22. How do you authenticate with SNMPv1?
- A. Username/password
  - B. Hash
  - C. Public string
  - D. Community string
23. What is the process Java programs identify themselves to if they are sharing procedures over the network?
- A. RMI registry
  - B. RMI mapper
  - C. RMI database
  - D. RMI process
24. What do we call an ARP response without a corresponding ARP request?
- A. Is-at response
  - B. Who-has ARP
  - C. Gratuitous ARP
  - D. IP response
25. What are the three times that are typically stored as part of file metadata?
- A. Moves, adds, changes



- B. Modified, accessed, deleted
  - C. Moved, accessed, changed
  - D. Modified, accessed, created
26. Which of these is a reason to use an exploit against a local vulnerability?
- A. Pivoting
  - B. Log manipulation
  - C. Privilege escalation
  - D. Password collection
27. What principle is used to demonstrate that a signed message came from the owner of the key that signed it?
- A. Nonrepudiation
  - B. Nonverifiability
  - C. Integrity
  - D. Authority
28. What is a viable approach to protecting against tailgating?
- A. Biometrics
  - B. Badge access
  - C. Phone verification
  - D. Man traps
29. Why is bluesnarfing potentially more dangerous than bluejacking?
- A. Bluejacking sends, while bluesnarfing receives.
  - B. Bluejacking receives, while bluesnarfing sends.
  - C. Bluejacking installs keyloggers.
  - D. Bluesnarfing installs keyloggers.
30. Which of the security triad properties does the Biba security model relate to?
- A. Confidentiality
  - B. Integrity
  - C. Availability
  - D. All of them

## Answers to Assessment Test

1. B. The destination address is used as the address to send messages to. The don't fragment bit is used to tell network devices not to fragment the packet. The Type of Service (ToS) field can be used to perform quality of service. The IP identification field is used to identify fragments of the same packet, as they would all have the same IP identification number.
2. C. A SQL injection attack makes use of SQL queries, which can include logic that may alter the flow of the application. In the example provided, the intent is to force the result of the SQL query to always return a true. It is quoted the way it is to escape the existing query already in place in the application. None of the other attacks uses a syntax that looks like the example.
3. C. The Apple App Store and the Google Play Store are controlled by Apple and Google. It's not impossible to get malware onto mobile devices that way, but it's very difficult because apps get run through a vetting process. While some Android devices will support external storage, it's not an effective way to get malware onto a smartphone or other mobile device. Jailbreaking can lead to malware being installed, but it's not the means to get malware onto a mobile device. Third-party app stores can be a good means to get malware onto mobile devices because some third-party app stores don't vet apps that are submitted.
4. B. DHCP is used to get IP configuration to endpoints. DNS is used to resolve a hostname to an IP address and vice versa. RARP is the reverse address protocol used to take a MAC address and resolve it to an IP address. ARP is used to resolve an IP address to a MAC address. Communication on a local network requires the use of a MAC address. The IP address is used to get to systems off the local network.
5. C. Heap spraying uses dynamically allocated space to store attack code. A slowloris attack is used to hold open web server connection buffers. A SQL injection will be used to inject SQL queries to the

database server. A buffer overflow sends more data into the application than space has been allocated for.

6. B. A /23 network would be 255.255.254.0. A /22 would be 255.255.252. A /20 would be 255.255.240.0. Only a /21 would give you a 255.255.248.0 subnet mask.
7. C. Both worms and viruses could be written to use polymorphic code, which means they could modify what they look like as they propagate. A worm, though, could self-propagate. It's the one distinction between worms and viruses. Viruses require some intervention on the part of the user to propagate and execute.
8. A. Risk is the probability of the occurrence of an event multiplied by the dollar value of loss. There is no mitigation factor that is quantified, so it couldn't be used for a risk calculation.
9. B. An evil twin attack uses an access point masquerading to be the point of connection for stations trying to connect to a legitimate wireless network. Stations reach out to make connections to this access point masquerading as another access point. While you may phish for credentials as part of an evil twin attack, credential phishing is not how evil twin attacks work. SSIDs don't get changed as part of an evil twin attack, meaning no SSID that exists will become another SSID. Injecting four-way handshakes won't do much, since four-way assumes both ends are communicating, so the injection of a full communication stream will get ignored.
10. C. Antivirus solutions are used on endpoints or maybe on email servers. Stateful firewalls add the ability to factor in the state of the connection—new, related, established. An Application layer gateway knows about Application layer protocols. A unified threat management appliance adds capabilities on top of firewall functions, including antivirus.
11. A. Standards and practices should be derived from a security policy, which is the high-level guidance on the role of security within an organization. Security does not generally increase the bottom line of a company. Policies are not for providing specific directions, which would be the role of procedures.

12. B. Base64 encoding takes nonprintable characters and encodes them in a way that they can be rendered in text. Encryption would generally render text unreadable to people. A cryptographic hash is a way of generating a fixed-length value to identify a value. URL encoding takes text and uses hexadecimal values to represent the characters. This is text that has been converted into hexadecimal so it can be used in a URL.
13. B. Mail exchanger records would be identified as MX records. A name server record is identified with the tag `ns`. While an enterprise may have one or even several caching name servers, the caching name server wouldn't be said to belong to the domain since it doesn't have any domain identification associated with it.
14. C. A DNS query can be used to identify an IP address from a host-name, or vice versa. You could potentially use a brute-force technique to identify hostnames, though you may not get everything using that method. A recursive request is common from a caching server to get an authoritative response. The term for getting all the contents of the zone is a zone transfer.
15. A. Tunneling attacks can be used to hide one protocol inside another. This may be used to send operating system commands using a tunnel system. A DNS amplification attack is where a small DNS request results in much larger responses sent to the target. DNS recursion is used to look up information from DNS servers. An XML entity injection attack is a web-based attack and wouldn't be found inside a DNS request.
16. D. There may be several reasons for performing a ping sweep. You likely want to identify responsive hosts on the network segment you are targeting. You may not, though, want to use a full port scan. ICMP is a lightweight protocol, and there is a chance it will be allowed through the firewall, since it's used for troubleshooting and diagnostics.
17. C. The NIST cybersecurity framework specifies five functions—identify, protect, detect, respond, recover.
18. B. Python interpreters may be considered to be slower to execute than a compiled program; however, the difference is negligible,

and generally speed of execution isn't much of a concern when it comes to malware. Python is not a hard language to learn, and there are a lot of community-developed libraries. One challenge, though, is that you may need a Python interpreter, unless you go through the step of getting a Python compiler and compiling your script. Windows systems wouldn't commonly have a Python interpreter installed.

19. B. The expression `host 192.168.10.5 is BPF indicating that tcp-dump` should only capture packets to and from 192.168.10.5. If you wanted to only get it to or from, you would need to modify host with `src` or `dest`.
20. C. Certificates can be revoked, but that's not what Diffie-Hellman is used for. Key management is a much broader topic than what Diffie-Hellman is used for. Diffie-Hellman is used for key exchange. It is a process that allows parties to an encrypted conversation to mutually derive the same key starting with the same base value.
21. D. While you might be imitating someone, imitation is not a social engineering principle. Neither social proof nor scarcity is at play in this situation. However, if you are calling from the help desk, you may be considered to be in a position of authority.
22. D. SNMPv3 implemented username and password authentication. With version 1, you used a cleartext community string. SNMP doesn't use hashes, and while the word *public* is often used as a community string, a public string is not a way to authenticate with SNMPv1.
23. A. Interprocess communications across systems using a network is called remote method invocation. The process that programs have to communicate with to get a dynamic port allocation is the RMI registry. This is the program you query to identify services that are available on a system that has implemented RMI.
24. C. When an ARP response is sent without a corresponding ARP request, it's an unexpected or unnecessary message, so it is a gratuitous ARP.
25. D. There are three date and time stamps commonly used in file metadata. When the file is created, that moment is stored. When a

file is accessed by a user, that moment is stored. When a file is modified, that moment is stored. Accessed is not the same as modified since accessing a file could be read-only. You could open a file, expecting to modify it but not ending up doing the modification. The access time still changes. While moves, adds, and changes may sometimes be referred to as MAC like modified, accessed, and created, those are not tasks associated with file times.

26. C. Local vulnerabilities are used against applications that are not listening on the network. This means they require you to be “local” to the machine and not remote. In other words, you have to be logged in somehow. A local vulnerability would not be used to collect passwords since you don't need a vulnerability to do that. Similarly, you don't need to make use of a vulnerability to manipulate logs or to pivot. Most of those would require you to have elevated permissions, though. A local vulnerability may be exploited to get you those elevated permissions.
27. A. Integrity is part of the CIA triad but isn't the principle that ties a signed message back to the subject of the signing certificate. Nonverifiability is nonsense, and authority isn't relevant here. Instead, nonrepudiation means someone can't say they didn't send a message if it was signed with their key and that key was in their possession and password-protected.
28. D. Biometrics and badge access are forms of physical access control. Phone verification could possibly be used as a way of verifying identity, but it won't protect against tailgating. A man trap, however, will protect against tailgating because a man trap allows only one person in at a time.
29. B. Bluesnarfing is an attack that connects to a Bluetooth device to grab data from that device. Bluejacking can be used to send information to a Bluetooth device that is receiving from the attacker, such as a text message. Neither of these attacks installs keyloggers. The victim device sends information to the attacker in a bluesnarfing attack.
30. B. The Biba security model covers data integrity. While other models cover confidentiality, none of them covers availability.

Table of contents collapsed